Анализ уязвимостей

1. Парольная политика

Настройки парольной политики

Опишите недостатки в парольной политике Weak Policy. Заполните таблицу.

Параметр	**Уязвимость**	**Предложения по закрытию уязвимости**
Длина пароля 6 символов	Короткий пароль	Минимум 8
Отключены требования к сложности пароля	брутфорс	Поставить требования к сложности
Нет блокировки учетных записей при неудачном вводе	брутфорс	Поставить ограниченное число попыток
Нет аудита входов в систему	Скрытая атака	включить
Учетная запись гость	Латеральное движение, проникновение в систему	отключить
Срок действия пароля	Устаревшие пароли, брутфорс через слитые базы	Установить срок жизни пароля

Проверка стойкости паролей, соответствующих политике

Впишите в таблицу результаты подбора как минимум 10 паролей из предложенных в домашнем задании.

Пароль	**Хеш**	**Оцените стойкость**	**Слабые места пароля**
Password1!	7FACDC498ED1680C4FD1448319A8C04F	низкая	Целое слово
$uperman1987	05E442961DDCEAFEE73DC32732D89DDF	средняя	Замена символами, но тоже есть слово
P@ssword2021	695FB66F05E07BF58173AE779E6C6B4F	Низкая	Слово, частая заменя а и собаку

!Princess123	E1BC92AECD8D2852ECCFA0BFC5486D48	низкая	Слово не очень расхожее думаю есть в каких то словарях, и 123 тоже не особо сильно
Ch@rlieBrown1	A1E50F351A41E2B30ED9FA17D0069FB8	средняя	Имя-фамилия с заменой, возможно есть в словарях
Sunsh1ne2010!	711A96B91425EB850E2DCB9A1F76ED1C	средняя	Цельное слово, с заменой символов
L0veU4ever!	37391A7448B60C7F85DF3A805C586EC6	средний	Много замен символов, но расхожая фраза
1q2w3e4r5t6y7u8i9o	679546CDF291E007CAAD1EDB21C6E748	низкая	Буквы с уифпами подряд на клавиатуре
e10adc3949ba59abbe56e057f20f883e	B3F2C51FB44A060158EF53D50DFEB1D3	низкая	Хеш пароля 123456
k.,jdm2022	4A345473CCE1FD276DBD45EA71E22F17	высокий	

Приложите ниже скриншот окна текстового редактора с **hashcat.potfile**.

Странно, с помощью трех больших словарей получилось только три пароля подобрать, техника освоена))))



Проверка стойкости установленных паролей

Проверьте стойкость установленных паролей 20 пользователей.

Видимо очередный баги сборки, в общем я видимо вытащил пароли реальной ВМ из папки NTDS, не установлены никакие пользователи, хотя было сделано по инструкции, но при этом лес, AD и политика установились и создались(честно очень много багов с сборках. Периодически что то не работает, приходится на это много времени убивать, некоторые ученики из-за этого реально бросили обучение). Зато в первой строке мой старый пароль, который я когда то использовал везде, он теперь в слитых базах, я это узнал))) не отправляй переделывать, технику же я освоил)))))))

Учётная запись	**Хеш**	**Результат подбора**
Administrator	ad69796aba310bf77880fbc8bff9b7d4	**AfFe1237**
Залетный	31d6cfe0d16ae931b73c59d7e0c089c0	**[not found]**
cloudbase-init	22909b1e3cc2ece3f530bacb4b349d56	**[not found]**
cloudbase-init	22909b1e3cc2ece3f530bacb4b349d56	**[not found]**

admin	a5749775d89288d95658b7a436e8f66b	**[not found]**
FHMHLLPUD3T2Q7J$	fc5709d60281fc86e37d650f7c19792f	**[not found]**
krbtgt	ae108ef54bf691cbbb8808600de36a82	**[not found]**

2. Доступ к объектам

Оцените ситуацию с предоставлением прав доступа к общим для организации файловым ресурсам сервера и службе, используемой для обмена файлами, принтерами и другими ресурсами по сети.

Опять же обьяснюсь, часть скрипта просто не установилась, я пытался запустить его еще раз, ничего не поменялось, ну если мы возьмем в рамках ВМ, то у нас диск С весь - Default share, в рамках политики доступа разных отделов, это очень плохо. В идеале к папкам с чувствительной информацией должен иметь доступ только пользователи с админскими правами.

Объекты доступа	**Уязвимость**	**Предложения по закрытию уязвимости**
Диск С - для всех	Любой может войти в смотреть файлы, латеральное движение, вытаскивание чувствительной информации	к папкам с чувствительной информацией должен иметь доступ только пользователи с админскими правами.

Короче получилось с 10 раза

NETVOL	Доступ EVERYONE	к папке с должны иметь доступ только пользователи с админскими правами

SYSLOGON	Доступ EVERYONE	к папке с должны иметь доступ только пользователи с админскими правами

3. Политика журналирования

Сформулируйте недостатки параметров журналирования в групповой политике **Weak Policy**.

Параметр	**Уязвимость**	**Предложения по закрытию уязвимости**
Размер журналов	Крайне мал (1МБ)	Хотя бы 1 гиг
Метод сохранения	Старые записи удалятся	Очистка вручную, архивировать
Нет параметра какие события должны записываться	Непонятно что журналируется	Поставить четкие позиции записи

4. Уязвимые сервисы

Опишите уязвимости сервисов и предложите **несколько** вариантов устранения уязвимостей.

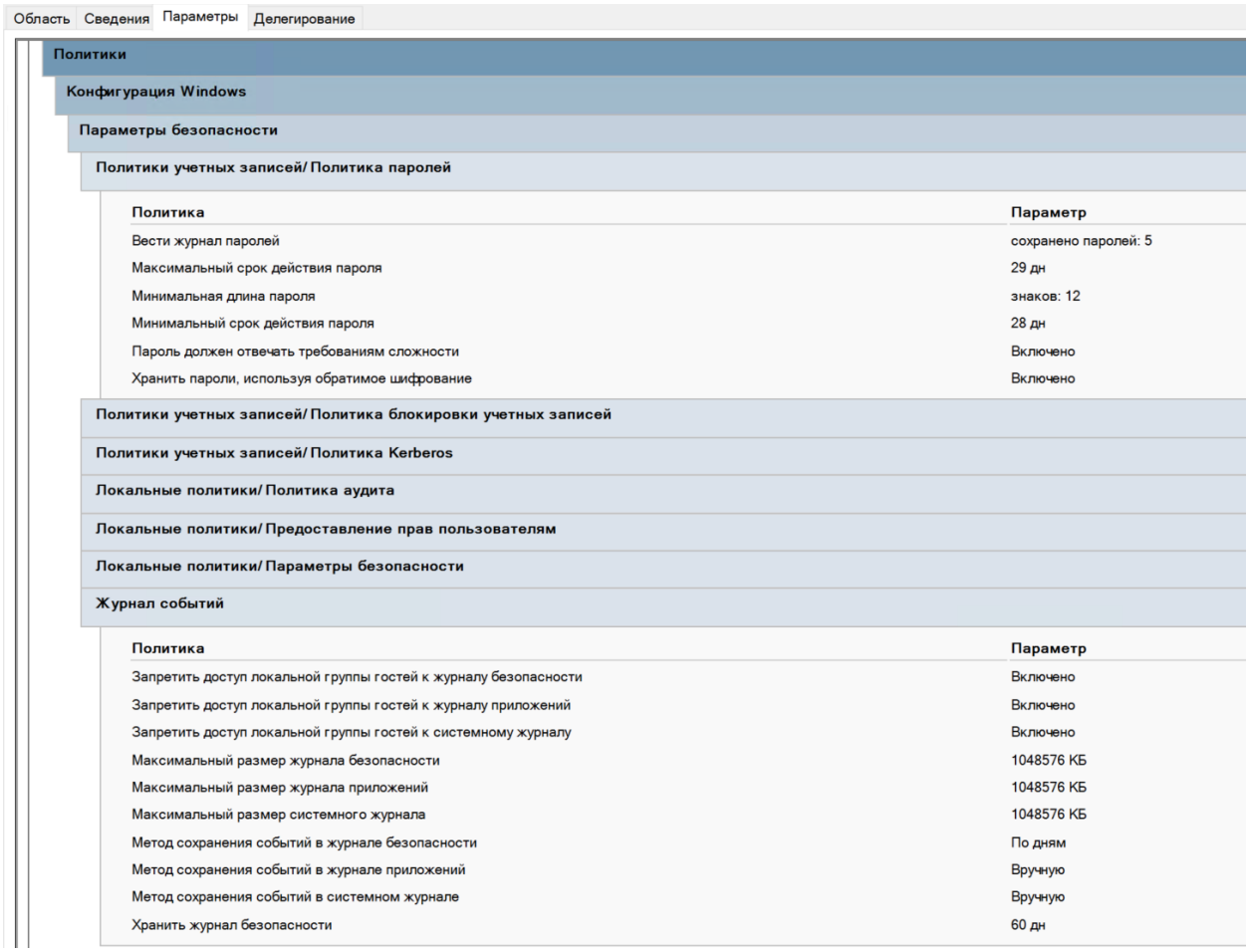
EternalBlue MS17-010 уязвимость в протоколе SMBv1. Позволяет атакующему удалённо выполнить код с наивысшими привилегиями.

Сервис	**Уязвимость**	**Предложения по закрытию уязвимости**
RDP	Прямой доступ к RDP из интернета, Отсутствие многофакторной аутентификации (MFA)	Запретить прямые подключения к контроллеру из интернета , включить многофакторную аутентификацию

Принтер	Служба печати часто запущена на контроллерах домена по умолчанию и позволяет удалённо выполнять код с системными привилегиями, политики позволяют обычным пользователям устанавливать драйверы при подключении к общим принтерам	Через политики запретить установку драйверов , отключить службу Print Spooler
Netlogon RPC DoS, CVE-2025-49716	Удалённый пользователь может полностью израсходовать всю память на контроллере домена, вызвав отказ в обслуживании	Обновление системы, в обновлении исправлено

5. Харденинг

Доработайте текущую групповую политику Weak Policy, изучив необходимые материалы. Приложите к отчёту выгрузку.



Область | Сведения | Параметры | Делегирование

Политики

Конфигурация Windows

Параметры безопасности

Политики учетных записей/ Политика паролей

Политика	Параметр
Вести журнал паролей	сохранено паролей: 5
Максимальный срок действия пароля	29 дн
Минимальная длина пароля	знаков: 12
Минимальный срок действия пароля	28 дн
Пароль должен отвечать требованиям сложности	Включено
Хранить пароли, используя обратимое шифрование	Включено

Политики учетных записей/ Политика блокировки учетных записей

Политики учетных записей/ Политика Kerberos

Локальные политики/ Политика аудита

Локальные политики/ Предоставление прав пользователям

Локальные политики/ Параметры безопасности

Журнал событий

Политика	Параметр
Запретить доступ локальной группы гостей к журналу безопасности	Включено
Запретить доступ локальной группы гостей к журналу приложений	Включено
Запретить доступ локальной группы гостей к системному журналу	Включено
Максимальный размер журнала безопасности	1048576 КБ
Максимальный размер журнала приложений	1048576 КБ
Максимальный размер системного журнала	1048576 КБ
Метод сохранения событий в журнале безопасности	По дням
Метод сохранения событий в журнале приложений	Вручную
Метод сохранения событий в системном журнале	Вручную
Хранить журнал безопасности	60 дн

Комментарии

Я не понял намек в задании на вход на ya.ru, можно поянение? Я понимаю, что открытый доступ в интернет это плохо, но если стоит firewall и прокси, то проблем нет, он также откроется, но с фильтрацией трафика, это же не какой то странный сайт.